
EduCampusHub

Comprehensive Website Audit Report

Website: <https://educampus-hub-beta.vercel.app>
Framework: Next.js 16 (App Router) + React + Tailwind CSS
Database: Neon PostgreSQL with Prisma ORM
Deployment: Vercel
Date: May 30, 2026

Executive Summary

This audit identified 27 issues across the EduCampusHub platform: 7 Critical, 8 High, 7 Medium, and 5 Low severity. The most impactful findings are: (1) the entire site is built as a Single-Page Application using client-side state routing, making all pages except the homepage return HTTP 404 from the server, which completely blocks Google indexing; (2) the Google OAuth system is completely non-functional due to placeholder credentials; (3) session tokens are never verified on protected API routes, enabling full authentication bypass; and (4) multiple unauthenticated API endpoints allow unauthorized listing creation, modification, and deletion. The site is currently not indexed by Google, has zero search visibility, and has significant security vulnerabilities that must be addressed before public launch.

Category	Score	Grade
Google Indexing	0/10	F
Site Architecture	1/10	F
Security	2/10	F
Authentication	2/10	F
SEO Configuration	8/10	B

Performance	7/10	B-
Mobile Responsiveness	9/10	A
PWA / Manifest	8/10	B
robots.txt	9/10	A

Overall Score: 5/100 (F)

1. Google Indexing Status

The website has zero presence on Google. When searching for "site:educampushub-beta.vercel.app", Google returns 0 results. A brand name search for "EduCampusHub" does not find the website either. Only competitors like e-campushub.com, campushub.io, and campusswap.in appear in search results. The Google Search Console verification tag is set to "PENDING", meaning the site has never been verified with Google, and no sitemap has been submitted.

Check	Result
site:educampushub-beta.vercel.app	0 results - NOT INDEXED
"EduCampusHub" brand search	Not found
Google Site Verification	PENDING - Not configured
Sitemap submitted to GSC	No

2. Site Architecture - Critical SPA Routing Issue

This is the single most critical issue affecting the entire platform. The application is built as a Single-Page Application (SPA) using Zustand client-side state routing. All navigation is handled through button click handlers that update a React state variable called "currentPage". The URL in the browser address bar NEVER changes from "/" during navigation. This means that every page except the homepage returns HTTP 404 when accessed directly by URL, which completely prevents Google from crawling or indexing any page beyond the homepage.

When a user navigates to "Explore" or "Categories", the page content changes but the URL remains as "/". If someone tries to share a link to a specific page, bookmark a page, or use the browser back/forward buttons, none of these work correctly. This also means that all 28 URLs listed in the sitemap.xml are dead links from Google's perspective, which wastes crawl budget and signals low quality to Google's algorithms.

URL	Server Status	Google Can Index?
/	200	Yes
/explore	404	No
/categories	404	No
/sell	404	No

/login	404	No
/privacy	404	No
/terms	404	No
/category/*	404	No

Recommended Fix: Convert to Next.js file-based routing by creating actual route files: `app/explore/page.tsx`, `app/categories/page.tsx`, `app/sell/page.tsx`, `app/login/page.tsx`, `app/terms/page.tsx`, `app/privacy/page.tsx`, and `app/category/[slug]/page.tsx`. Replace button click handlers with Next.js Link components.

3. Authentication System Audit

The authentication system has multiple critical vulnerabilities that make it unsuitable for production use. While the login and registration forms render correctly in the UI and accept user input, the backend implementation has fundamental security flaws that would allow any attacker to bypass authentication, impersonate users, and perform unauthorized actions.

3.1 Google OAuth - Completely Non-Functional

The Google Sign-In button is visible in the login UI but will always fail because the OAuth credentials are placeholders. The `.env` file contains `"GOOGLE_CLIENT_ID=your-google-client-id-here"` and a matching placeholder for the client secret. Additionally, the client-side Google sign-in button points to `"/api/auth/google"`, but NextAuth expects the route to be `"/api/auth/signin/google"`. Even if the credentials were correct, clicking the button would hit a 404.

Fix: Register the application at Google Cloud Console, create OAuth 2.0 credentials, set the redirect URI to `https://educampushub-beta.vercel.app/api/auth/callback/google`, update the `.env` file with real credentials, and fix the client-side URL to `"/api/auth/signin/google"`.

3.2 Passwordless Signup Backdoor

A critical vulnerability exists in the authentication route handler (`src/app/api/auth/route.ts`, lines 232-268). When the `"action"` parameter is not `"register"`, `"login"`, or `"logout"`, the handler falls through to a legacy backward-compatibility flow that creates a user account with just an email address and no password. This allows anyone to create accounts under any email address without authentication, providing full platform access with zero verification.

Fix: Remove lines 231-268 entirely from the auth route handler. This legacy code serves no legitimate purpose.

3.3 Session Tokens Never Verified

The session_token httpOnly cookie is set upon successful login or registration, but no protected API route ever reads or verifies this token. Instead, all protected endpoints accept a "userId" parameter directly from the request body or query string. This means any client can impersonate any user by simply passing a different userId value. There is no server-side mechanism equivalent to the getAdminFromCookies() helper that exists for admin routes.

Fix: Create a getUserFromCookies() helper function that extracts and verifies the session token, and use it in all protected API routes. Replace all instances of userId from request body with userId from the verified session.

3.4 Weak JWT Secret

The JWT secret in production is "educampushub-jwt-secret-2024-secure-prod", a human-readable string that can be easily guessed. Additionally, the auth route has a hardcoded fallback secret "educampushub-insecure-dev-secret-change-me" that activates if the environment variable is missing. An attacker who guesses or obtains this secret can forge any session token and impersonate any user including administrators.

Fix: Generate a cryptographically random secret using "openssl rand -base64 64", set it as the JWT_SECRET environment variable in Vercel, and remove the hardcoded fallback from the source code, replacing it with a startup crash if the variable is not set.

3.5 Forgot Password - Non-Functional

The "Forgot Password?" link in the login form has no onClick handler and does nothing when clicked. There is no password reset flow implemented anywhere in the codebase. Users who forget their passwords have no recovery path.

3.6 No Email Verification

Users register with isVerified: false but there is no mechanism to verify email addresses. No verification email is sent, no verification token is generated, and no verification endpoint exists. This allows spam accounts and fake emails.

4. Security Vulnerabilities

ID	Severity	Issue	Impact
C-1	CRITICAL	Database credentials exposed in .env file with plaintext password	Full database compromise
C-2	CRITICAL	Unauthenticated listing PATCH and DELETE - no authorization checks	Listing vandalism, data loss
C-3	CRITICAL	Mass assignment vulnerability in users API - no field whitelist	Privilege escalation
C-4	CRITICAL	Mass assignment vulnerability in listings API - no field whitelist	Fake verification, impersonation
H-1	HIGH	Payment endpoints have no authentication - userId from request body	Payment fraud
H-2	HIGH	Hardcoded personal UPI ID as fallback in payment route	Financial misdirection
H-3	HIGH	NODE_ENV=development in production .env file	Insecure cookies, info leaks
H-4	HIGH	User data persisted unencrypted in localStorage including isAdmin	Client-side privilege escalation
M-1	MEDIUM	CSP allows unsafe-inline and unsafe-eval in script-src	XSS attack risk
M-2	MEDIUM	In-memory rate limiting broken in serverless (Vercel)	No effective rate limiting
M-3	MEDIUM	Unbounded pagination limit allows ?limit=999999 DoS	Database overload
L-1	LOW	Case-sensitive search in listings API	Poor search UX

5. SEO Configuration Analysis

5.1 What Is Working Well

The on-page SEO implementation is actually quite good. The homepage has comprehensive meta tags including title (48 characters), description (156 characters), keywords (24 terms), robots directives, canonical URL, and author information. Open Graph tags are present for social sharing with correct og:title, og:description, og:url, og:site_name, og:locale (en_IN), og:type, and og:image with proper dimensions. Three JSON-LD structured data schemas are included: Organization, WebSite (with SearchAction for sitelinks search box), and a WebPage schema. The PWA manifest is correctly configured with icons at 192x192 and 512x512 sizes. The robots.txt is well-structured, properly blocking admin and API

paths while allowing search engine crawlers.

5.2 Critical SEO Issues

Issue	Severity	Impact
SPA routing makes all pages 404	CRITICAL	Only homepage is crawlable by Google
Sitemap lists 28 URLs that all return 404	CRITICAL	Wastes crawl budget, signals low quality
Google Search Console not verified (PENDING)	HIGH	Cannot submit sitemap or monitor indexing
cache-control: no-store on all pages	HIGH	Prevents CDN caching, hurts crawl efficiency
No product/listing pages in sitemap	MEDIUM	DB query may be failing, 0 product URLs
No per-page metadata	MEDIUM	All pages share homepage title/description
Missing twitter:site and twitter:creator	LOW	Incomplete Twitter card
OG image inconsistency between og:image and twitter:image	LOW	Confusing for social crawlers

6. API Endpoints & Database

All API endpoints are accessible and respond correctly in terms of HTTP status codes. The database connection is functional with 7 registered users but 0 listings, 0 colleges, and 0 active listings, which is expected for a beta site. Rate limiting is implemented but uses in-memory storage which does not work in Vercel's serverless environment, making it effectively non-functional.

Endpoint	Status	Response Time	Notes
GET /api/listings	200	2.15s	Slow for empty result
GET /api/auth	405	0.57s	POST-only, expected
GET /api/stats	200	5.52s	Very slow, cold start
GET /api/users	401	0.59s	Properly protected
GET /sitemap.xml	200	0.74s	Valid XML, 28 URLs
GET /robots.txt	200	0.12s	Well-structured

Database Performance Concern: The /api/stats endpoint takes 5.52 seconds to respond, likely due to Neon PostgreSQL cold starts. The NextAuth session callback also queries the database on every session token validation, which severely degrades performance. Consider implementing connection pooling and caching session data in the JWT token rather than querying the database on every request.

7. Performance & Responsiveness

Metric	Value	Assessment
Homepage TTFB	324ms	Good
Homepage total load	528ms	Good
HTML transfer size	13.7 KB	Lightweight
Font preload	6 files	Optimized
Mobile viewport	Correct	Responsive
PWA manifest	Valid	Configured
Security headers	6/7 present	Good
HTTPS redirect	308 redirect	Working
API /stats response	5.52s	Very slow

8. Complete Issue List (27 Issues)

#	Severity	Issue	Recommended Fix
1	CRITICAL	SPA routing - all pages except / return 404	Convert to Next.js file-based routing
2	CRITICAL	Google OAuth credentials are placeholders	Configure real Google Cloud Console credentials
3	CRITICAL	Passwordless signup backdoor in auth handler	Remove lines 231-268 from auth route
4	CRITICAL	Session tokens never verified on protected routes	Create getUserFromCookies() helper
5	CRITICAL	Unauthenticated listing PATCH/DELETE	Add auth + ownership verification

6	CRITICAL	Mass assignment in users API	Whitelist allowed update fields
7	CRITICAL	Mass assignment in listings API	Whitelist allowed update fields
8	HIGH	Google Sign-In URL incorrect (/api/auth/google)	Change to /api/auth/signin/google
9	HIGH	Weak/predictable JWT secret in production	Generate with openssl rand -base64 64
10	HIGH	Hardcoded fallback JWT secret in source	Replace with startup crash if missing
11	HIGH	Payment endpoints have no authentication	Verify session, extract userId from token
12	HIGH	Hardcoded personal UPI ID as fallback	Remove fallback, crash if UPI_ID missing
13	HIGH	NODE_ENV=development in production .env	Remove from .env, Vercel sets automatically
14	HIGH	User data in localStorage includes isAdmin	Remove sensitive fields from persisted state
15	HIGH	Google Search Console not verified	Replace PENDING with real verification code
16	MEDIUM	Dual rate limiting implementations	Consolidate into single implementation
17	MEDIUM	In-memory rate limiting broken in serverless	Use Upstash Redis for serverless
18	MEDIUM	NextAuth session callback DB query on every access	Cache in JWT token instead
19	MEDIUM	CSP allows unsafe-inline and unsafe-eval	Use nonce-based CSP for production
20	MEDIUM	No email verification flow	Implement verification email + endpoint
21	MEDIUM	Forgot Password button non-functional	Implement password reset flow
22	MEDIUM	Unbounded pagination limit	Cap at maximum 100 results
23	LOW	Duplicate FREE_UPLOAD_LIMIT constant	Extract to shared constants file
24	LOW	NextAuth uses non-standard secret env var	Use NEXTAUTH_SECRET convention

2 5	LOW	Case-sensitive search in listings	Add mode: insensitive to Prisma query
2 6	LOW	Logout does not clear client store	Call setCurrentUser(null) on logout
2 7	LOW	Sitemap lastmod always = new Date()	Use actual content modification dates

9. Priority Action Plan

Phase 1: Critical Security Fixes (Immediate - Before Any Public Launch)

These fixes must be implemented before the website is accessible to any real users. They address authentication bypass, data exposure, and unauthorized access vulnerabilities that could result in data breaches, financial fraud, and complete platform compromise.

- Rotate ALL secrets: database password, JWT secret (generate with openssl rand -base64 64), admin credentials
- Remove the passwordless signup backdoor (lines 231-268 from auth/route.ts)
- Add session verification to ALL protected API routes using a new getUserFromCookies() helper
- Add field whitelisting to PATCH endpoints for both users and listings APIs
- Add authentication and authorization to listing PATCH/DELETE endpoints
- Remove hardcoded fallback secrets and UPI IDs; crash on missing environment variables instead
- Remove currentUser from localStorage persistence or strip isAdmin/adminRole/isBanned fields
- Remove NODE_ENV=development from .env file

Phase 2: Core Functionality Fixes (Within 1 Week)

These fixes address the fundamental architectural and functional issues that prevent the site from being usable as a real product. Without these, users cannot properly navigate, authenticate via Google, or recover their accounts.

- Convert SPA routing to Next.js file-based routing (the single most impactful fix)
- Configure real Google OAuth credentials and fix the sign-in URL
- Implement email verification flow for new registrations

- Implement password reset flow (currently the Forgot Password button does nothing)
- Verify Google Search Console and submit sitemap after routing fix
- Fix cache-control headers to allow CDN caching for public pages
- Create proper /privacy and /terms pages for legal compliance

Phase 3: SEO & Performance Optimization (Within 1 Month)

- Add per-page metadata with generateMetadata() for each route
- Add BreadcrumbList and Product structured data schemas
- Fix sitemap to use actual content modification dates
- Implement serverless-compatible rate limiting with Upstash Redis
- Optimize /api/stats response time (currently 5.52s)
- Tighten CSP by removing unsafe-inline and unsafe-eval
- Consider path-based internationalization (/en/, /hi/, /gu/) instead of query parameters
- Add pagination limits and case-insensitive search to listings API

10. What Is Working Well

- Homepage renders fully with all sections and no JavaScript errors
- Security headers are comprehensive (HSTS, X-Frame-Options, CSP, Permissions-Policy, Referrer-Policy)
- HTTP to HTTPS redirect works correctly with 308 status code
- Login and registration forms are complete and functional with proper validation
- Mobile responsive design works well with proper viewport and bottom navigation
- Custom 404 page with proper noindex meta tag
- robots.txt properly blocks admin and API paths while allowing search crawlers
- PWA manifest correctly configured with proper icons and metadata
- Brand logo and color scheme correctly updated to match official design
- Instagram integration with @educampushubofficial in hero section and footer
- Multi-language support (English, Hindi, Gujarati) with language switcher
- Dark mode implementation with proper theme switching